

Information Security Standard for Suppliers

Calder Financial Group plc | Third Party Security Standard TPS-2024 rev.2 | Referenced at Articles 3.2 and 14.1

This Standard applies to every supplier processing Company Data or connecting to Company systems. Compliance is a contractual obligation under the Master Agreement for Supplier Services. Deviations require a documented exception approved by the Company's Chief Information Security Officer.

1. ACCESS CONTROL

Multi-factor authentication for all administrative and remote access. Access reviewed quarterly and revoked within twenty-four hours of a leaver event. No shared accounts. Privileged access recorded and session-logged.

2. ENCRYPTION

Company Data encrypted in transit using TLS 1.2 or above, and at rest using AES-256 or an equivalent approved algorithm. Key management documented and keys rotated at least annually.

3. VULNERABILITY AND PATCH MANAGEMENT

Severity	Remediation window
Critical	72 hours
High	14 days
Medium	60 days

4. INCIDENT MANAGEMENT

The supplier shall notify the Company of any actual or suspected security incident affecting Company Data **within twenty-four hours** of becoming aware of it, and shall provide a written root cause analysis within ten business days of closure.

5. RESILIENCE

Documented business continuity and disaster recovery plans, tested at least annually, with a recovery time objective of four hours and a recovery point objective of fifteen minutes for services supporting a material outsourcing.

6. ASSURANCE

Annual independent penetration test, with the summary report provided to the Company on request. Current ISO/IEC 27001 certification or an equivalent recognised by the Company. Annual completion of the Company's third party security questionnaire.

7. PERSONNEL

Background screening for all personnel with access to Company Data, to the standard applicable in the relevant jurisdiction, and annual security awareness training.

This synthetic security standard is designed for contract-lifecycle demonstrations. Names, terms, and provisions are fictional and are not legal advice.